

THE FORENSICS WAY

ISSUE 35

FORENSICS AWARENESS THIS WEEK

TUESDAY, SEPTEMBER 29, 2026

FRONT PAGE

ZERO-DAY

The Gatekeeper With No Gate: A CVSS 10.0 Cisco ISE Flaw Under Active Attack Turns the Identity Layer Into the Soft Target

Cisco disclosed a critical zero-day in Identity Services Engine, tracked as CVE-2026-76460 and rated CVSS 10.0, already under active exploitation. The flaw stems from insufficient authentication control on an API endpoint, allowing a remote attacker with no credentials to bypass authentication entirely. ISE is not an ordinary application: it is the policy engine that decides which devices and users are allowed onto a network, what they may reach once admitted, and which posture checks they must satisfy — a single appliance whose judgment every downstream segment inherits.

That position is what makes this more than another appliance bug. An attacker who reaches administrative control of the identity layer does not need to defeat the controls behind it; they can simply be granted permission to walk past them, and the resulting access looks entirely legitimate in every log that records it. Forensic priority: patch on the emergency track rather than the maintenance cycle, and treat authorization decisions themselves as evidence — export ISE policy and authorization logs for the full exposure window and reconcile every network admission against an independent source such as switch port and DHCP records. Any endpoint admitted by a policy that cannot be traced to a legitimate administrative change should be treated as attacker-placed, and administrator accounts, certificates, and RADIUS shared secrets should be rotated on the assumption that the appliance's own account store was readable.

SUPPLY CHAIN

The Recommendation Was the Payload: An Attacker Rides a Live AI Coding-Assistant Session Into 100 Internal Repositories

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-94127

F5 BIG-IP APM — a heap-based buffer overflow in the Access Policy Manager, the component that brokers remote access and SSO for the environments behind it. Added to CISA KEV on September 22. *Forensic Note:* Patch to a fixed BIG-IP release and review APM access and session logs for malformed requests or unexplained crashes and restarts, which often precede successful memory-corruption exploitation; treat any APM-brokered session established during the exposure window as requiring re-authentication.

ACTIVE EXPLOIT

CVE-2026-85102 / CVE-2026-93616

Check Point — an improper certificate-validation flaw alongside a path-traversal flaw across multiple products, both added to CISA KEV on September 22. Weak certificate validation undermines the assumption that an authenticated peer is who it claims to be. *Forensic Note:* Apply vendor fixes, audit gateway logs for connections accepted with unexpected or mismatched certificates, and review file access outside expected directories as the primary path-traversal indicator.

MALWARE SPOTLIGHT

KREMLIN — The Banking Toolkit That Lives in the Browser, Not the Binary

Mandiant documented an intrusion at an unnamed SaaS provider in which an attacker took over a developer's active AI coding-assistant session and used the developer's own authenticated context as the attack path. The assistant recommended a third-party package the attacker had already poisoned; the developer accepted the suggestion, and the poisoned dependency delivered an infostealer. With GitHub OAuth tokens harvested from that foothold, the attacker deployed a self-spreading worm — the same Shai-Hulud family seen in earlier registry campaigns — across roughly 100 internal repositories, taking repository secrets and product source code with it. The public case study does not say how the session was taken over or when the intrusion occurred.

The forensic lesson is about where trust actually sits. A developer reviews a dependency suggestion the way they review a colleague's recommendation, not the way they review an email attachment, and an assistant operating inside an authenticated session inherits every permission that session holds. Forensic priority: check AI-recommended third-party dependencies against cryptographic checksums and an approved allowlist before they are accepted, keep raw API keys and long-lived OAuth tokens out of direct reach of editor extensions and assistants, and route dependency traffic through a controlled internal repository so that what a developer installs is auditable after the fact. During an investigation, treat assistant session logs and dependency-resolution records as first-order evidence — they may be the only place the initial decision is recorded.

Researchers this week detailed KREMLIN, a previously undocumented Brazilian banking malware ecosystem active since May 2025. It chains multi-stage JavaScript loaders with custom C++ installers whose real purpose is to plant malicious Chrome and Edge extensions, which then harvest credentials and session tokens from inside the browser itself. Because the theft happens in an already-authenticated browser context, stolen session tokens can carry an attacker past multi-factor authentication without ever touching a password prompt. *Forensic Note:* Inventory installed browser extensions against an approved list and review extension install timestamps against the suspected infection window, hunt for unexpected extension-loading policies written to the registry, and treat every active banking or SSO session on an affected profile as compromised rather than merely exposed.

THE FORENSICS WAY

HISTORICAL ARCHIVES

HISTORY OF DIGITAL INVESTIGATION

TUESDAY, SEPTEMBER 29, 2026

CASE STUDIES: HISTORICAL GRID

OPERATION CLOUD HOPPER (2017)

One Door, Every Building: The Campaign That Made Managed Service Providers the Highest-Value Target in the Chain

THE FAKE RESEARCHER CAMPAIGN (2021)

Targeting the People Who Hunt: When Attackers Built a Research Community to Reach Its Members

In January 2021, Google's Threat Analysis Group exposed a North Korea-linked operation that

Disclosed in April 2017 by PwC and BAE Systems, Operation Cloud Hopper documented how APT10 compromised managed service providers and then used the legitimate, trusted connections those providers held into client networks to reach an unprecedented breadth of victims across a dozen countries. Investigators faced a defining difficulty: from a client's perspective, the attacker's traffic arrived over exactly the channel their IT provider was supposed to use, at exactly the times support work normally happened. The case established that compromising the layer everyone trusts beats compromising anyone individually — the same logic that makes this week's Cisco ISE flaw dangerous, where the appliance being subverted is the one that decides who is trusted at all.

spent months constructing a credible security-research presence — a research blog, guest posts, social media personas with genuine follower networks — for the sole purpose of approaching working vulnerability researchers and inviting them to collaborate on projects that carried a hidden payload. Several targets were compromised despite being precisely the audience most equipped to spot a malicious file, because the lure did not arrive as a file from a stranger; it arrived as a professional opportunity from a peer. It is the clearest ancestor of this week's AI-assistant case, where the compromise likewise rode in through a trusted recommendation rather than an obvious attack.

REGIN (2014)

The Platform That Loaded Only What It Needed: A Six-Stage Espionage Framework Built for Any Target

Discovered by Symantec in November 2014 after years of quiet operation against telecoms, governments, and research institutions, Regin was a modular espionage platform deployed across six discrete stages, each conditionally loaded depending on what the specific target environment required — a bespoke capability set assembled on the fly rather than a fixed toolkit. Its architecture treated "what to do next" as a decision made per-target rather than hardcoded in advance, requiring investigators to reconstruct the full stage chain across memory and disk before understanding what any single infection was actually capable of.

THE PEGASUS PROJECT (2021)

Zero Clicks, Total Access: How Commercial Spyware Sold to Governments Became a Tool Against Journalists Worldwide

In July 2021, a consortium of journalists and Amnesty International's Security Lab revealed that NSO Group's Pegasus spyware — sold exclusively to government clients — had been used against journalists, human-rights defenders, and political dissidents across dozens of countries, often via zero-click exploits requiring no victim interaction at all. Forensic analysis relied on Mobile Verification Toolkit examination of device backups to find traces the spyware was designed to leave almost none of, establishing device-forensics methodology that human-rights investigators still use today.

TOOLS OF THE TRADE

OPEN SOURCE

UAC

UNIX-LIKE ARTIFACTS
COLLECTOR — V3.X

Live artifact collection for Linux, macOS, and Unix-based appliances, driven

OPEN SOURCE

box-js

CAPACITORSET — V1.9.X

Analysis sandbox for malicious JavaScript that emulates the Windows scripting host and records

COMMERCIAL

Mandiant Advantage

GOOGLE CLOUD — THREAT
INTELLIGENCE

Threat-intelligence platform pairing finished intelligence with indicator

UTILITY / SCRIPT

Aftermath

JAMF — V2.X

Swift-based macOS incident-response collector that gathers browser data, persistence

by editable YAML profiles and requiring no agent installation. Well suited to triaging the Linux-based platform under an identity appliance like ISE, where a full disk image is impractical but configuration, log, and process state must be preserved before a patch overwrites them.

what a script attempts rather than executing it for real. Built for exactly KREMLIN's multi-stage loader chain: recover the intermediate stages and the URLs a loader would have contacted without detonating it on a live host.

and actor tracking, from the team behind this week's AI coding-assistant case study. Use it to check whether a dependency, package maintainer, or infrastructure indicator surfacing in a build pipeline is already attributed before deciding how far an investigation needs to reach.

locations, process and network state, then parses the results into an analyst-ready timeline. Deploy it to developer and researcher Macs after a suspected infostealer hit to establish what browser-resident credential material was actually reachable.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-5430 (WSO2 API MANAGER)

Improper cryptographic-signature verification lets a JWT signed with an unsupported algorithm bypass authentication; CVSS 9.8, with forged administrator tokens observed in the wild. *Forensic Note:* Review JWT validation logs for unexpected signing algorithms and audit every administrator account created or modified since mid-September.

ARCHIVE ALERT

CVE-2026-51990 (TENCENT SOGOU INPUT METHOD)

One-click RCE in a Windows input method with hundreds of millions of installs, exploited by China-aligned UNC3569 to deploy the GrayRabbit backdoor. Patched in 16.3.0.3498. *Forensic Note:* Confirm the updated version on every Windows host and audit URI-handler invocation history.

RECENT MALWARE WATCH

ARCHIVE: SEPTEMBER 22, 2026

GRAYRABBIT — THE BACKDOOR RIDING A CHINESE INPUT METHOD'S CHROMIUM FLAW

Modular backdoor linked to UNC3569, delivering a reverse shell plus plugin loading, file upload, and system reconnaissance through a keyboard utility. Hunt reverse-shell connections originating from IME-related processes.

ARCHIVE: SEPTEMBER 15, 2026

PIVOTC2 — THE RAT RIDING FORTIGATE'S BUFFER OVERFLOW

Confirmed post-exploitation payload for CVE-2025-25249, giving attackers a pivot point inside compromised FortiGate appliances. Hunt unexpected outbound connections originating from the appliance itself rather than protected hosts.